PUBLIC KEY INFRASTRUCTURE

S01: Architecture, Trust Hierarchy & Threat Models

Nguyen An Khuong, *CSE-HCMUT*
ORCID: 0000-0002-9910-6387 · Email: nakhuong@hcmut.edu.vn

Ho Chi Minh City University of Technology (HCMUT), VNU-HCM
Faculty of Computer Science and Engineering
Teaching Assistant: Mr. Nguyen Huu Hoang Huy (LinkedIn Profile)

Session 1 of 9 · ATHK 512 (KMA CHAT4P, HK261)
Class: Sat 03/10/2026 · 13h30–18h30
Standards: IETF RFC 5280, CA/B Forum, Decision 1875/QĐ-TTg

1. Lộ trình Học phần & Chuẩn Đầu ra

Lộ Trình Học Phần (9 Buổi Thực Chiến)

S01: Architecture, Trust & Threat Models	S02: X.509, ASN.1 & Path Validation	S03: CA Lifecycle & ACME Protocol
S04: Revocation (CRL/OCSP) & Hardware HSM	S05: TLS 1.3 & mTLS Zero Trust Gateway	S06: Certificate Transparency (CT) Logs & Merkle Tree
S07: PQC Migration NIST FIPS 203/204	S08: Enterprise AD CS Attack & Defense	S09: Capstone Defense & Audit Synthesis

Học phần tập trung vào thiết kế, thẩm định và vận hành hạ tầng PKI cấp doanh nghiệp, chuẩn bị di chuyển sang Mật mã Hậu lượng tử (PQC).



S1-1 · Lộ Trình Học Phần (9 Buổi Thực Chiến)

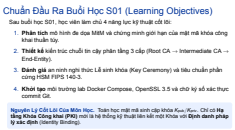
[2 phút | 13h30–13h32] Chào toàn thể 15 học viên cao học lớp CHAT4P. Đây là buổi thứ nhất trong 9 buổi học thực chiến của môn Cơ sở hạ tầng khóa công khai (ATHK 512). Bản đồ lộ trình trên slide cho thấy rõ kết cấu môn học: 6 buổi đầu là các trụ cột kỹ thuật cốt lõi từ kiến trúc phân tầng CA, chuẩn dữ liệu X.509 ASN.1, tự động hóa ACME, thu hồi chứng chỉ qua SoftHSM, mTLS Zero Trust, cho đến kiểm định CT Logs và di chuyển sang PQC. Ba buổi cuối là giai đoạn thẩm định và bảo vệ đồ án chuyên đề trước Hội đồng.

Chuẩn Đầu Ra Buổi Học S01 (Learning Objectives)

Sau buổi học S01, học viên làm chủ 4 năng lực kỹ thuật cốt lõi:

1. **Phân tích** mô hình đe dọa MitM và chứng minh giới hạn của mật mã khóa công khai thuần túy.
2. **Thiết kế** kiến trúc chuỗi tin cậy phân tầng 3 cấp (Root CA $\rightarrow$ Intermediate CA $\rightarrow$ End-Entity).
3. **Đánh giá** an ninh nghi thức Lễ sinh khóa (Key Ceremony) và tiêu chuẩn phần cứng HSM FIPS 140-3.
4. **Khởi tạo** môi trường lab Docker Compose, OpenSSL 3.5 và chữ ký số xác thực commit Git.

Nguyên Lý Cốt Lõi Của Môn Học. Toán học mật mã sinh cặp khóa $K_{\text{pub}}/K_{\text{priv}}$. Chỉ có **Hạ tầng Khóa Công khai (PKI)** mới là hệ thống kỹ thuật liên kết một Khóa với **Định danh pháp lý xác định** (Identity Binding).


Chuẩn Đầu Ra Buổi Học S01 (Learning Objectives)

Sau buổi học S01, học viên làm chủ 4 năng lực kỹ thuật cốt lõi:

1. **Phân tích** mô hình đe dọa MitM và chứng minh giới hạn của mật mã khóa công khai thuần túy.
2. **Thiết kế** kiến trúc chuỗi tin cậy phân tầng 3 cấp (Root CA → Intermediate CA → End-Entity).
3. **Đánh giá** an ninh nghi thức Lễ sinh khóa (Key Ceremony) và tiêu chuẩn phân cứng HSM FIPS 140-3.
4. **Khởi tạo** môi trường lab Docker Compose, OpenSSL 3.5 và chữ ký số xác thực commit Git.

Nguyên Lý Cốt Lõi Của Môn Học. Toàn học mật mã sinh cặp khóa K_{PUB}/K_{PRI}. Chỉ có **Hạ tầng Khóa Công khai (PKI)** mới là hệ thống kỹ thuật liên kết một Khóa với **Định danh pháp lý xác định** (Identity Binding).

S1-2 · Chuẩn Đầu Ra Buổi Học S01 (Learning Objectives)

[3 phút | 13h32–13h35] Nhấn mạnh sự khác biệt giữa Cryptography và PKI: Toán học rất mạnh, nhưng nếu Alice nhận được một public key mà không có bằng chứng chứng minh key đó thuộc về Bob, Alice sẽ bị tấn công MitM ngay lập tức. PKI là cầu nối giữa thế giới số học và thế giới thực.

Quy Chế Học Phần & Barem Đánh Giá 100 Điểm

Thành Phần Điểm Đánh Giá:

- **Chuyên cần & Thảo luận (10%):** Điểm danh và đóng góp bài học.
- **Thực hành Lab (20%):** 5 bài lab nộp báo cáo kèm log thực thi và chữ ký Git.
- **Đồ án Chuyên đề Nhóm (30%):** 5 nhóm kỹ thuật bảo vệ tại S07–S09.
- **Thi Cuối Kỳ KMA (40%):** Đề thi trắc nghiệm & tự luận tích hợp.

Quy Định Nộp Bài & Liêm Chính.

- Mọi mã nguồn thực nghiệm bắt buộc commit lên repo GitHub/GitLab của nhóm.
- Bắt buộc cấu hình chữ ký số commit bằng SSH key hoặc GPG.
- Nghiêm cấm sao chép báo cáo giữa các nhóm.



S1-3 · Quy Chế Học Phần & Barem Đánh Giá 100 Điểm

[3 phút | 13h35–13h38] Giải thích rõ thang điểm 100 và điều kiện đạt môn học. Nhấn mạnh việc chấm bài dựa trên evidence log thực thi trên hệ thống lab của từng nhóm.

2. Mô hình Đe dọa & Giới hạn Mật mã Khóa công khai

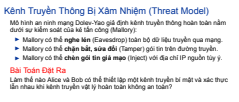
Kênh Truyền Thông Bị Xâm Nhiệm (Threat Model)

Mô hình an ninh mạng Dolev-Yao giả định kênh truyền thông hoàn toàn nằm dưới sự kiểm soát của kẻ tấn công (Mallory):

- Mallory có thể **nghe lén** (Eavesdrop) toàn bộ dữ liệu truyền qua mạng.
- Mallory có thể **chặn bắt, sửa đổi** (Tamper) gói tin trên đường truyền.
- Mallory có thể **chèn gói tin giả mạo** (Inject) với địa chỉ IP nguồn tùy ý.

Bài Toán Đặt Ra

Làm thế nào Alice và Bob có thể thiết lập một kênh truyền bí mật và xác thực lẫn nhau khi kênh truyền vật lý hoàn toàn không an toàn?



S1-4 · Kênh Truyền Thông Bị Xâm Nhiệm (Threat Model)

[2 phút | 13h38–13h40] Phân tích mô hình tấn công Dolev-Yao: Mọi kết nối Internet mặc định đều không an toàn. Kẻ tấn công có thể là router trung gian, nhà mạng, hoặc hacker cùng mạng Wi-Fi.

Cuộc Tấn Công Mạo Danh Man-in-the-Middle (MitM)



Hậu quả: Mallory thiết lập 2 phiên mã hóa độc lập với Alice và Bob. Mọi tin nhắn của Alice gửi cho Bob đều bị Mallory giải mã, đọc nội dung, sửa đổi rồi mã hóa lại gửi cho Bob mà không bên nào hay biết!



S1-5 · Cuộc Tấn Công Mạo Danh Man-in-the-Middle (MitM)

[3 phút | 13h40–13h43] Minh họa trực quan cuộc tấn công MitM kinh điển trên giao thức Diffie-Hellman không xác thực. Đây là lý do ra đời của PKI.

Nghịch Lý Khóa Công Khai & Bản Chất Của PKI

Nghịch lý: Mật mã bất đối xứng giải quyết bài toán chia sẻ khóa bí mật, nhưng lại sinh ra bài toán xác thực khóa công khai!

- Alice nhận được khóa K_{pub}, nhưng làm sao Alice biết chắc chắn khóa đó là của Bob chứ không phải của Mallory?
- Nếu dùng một khóa khác để xác thực khóa này, lại cần khóa thứ ba... dẫn tới vòng lặp vô tận!

Giải Pháp Của Hệ Thống PKI: Bên Thứ Ba Đáng Tin Cậy

Cần một thực thể có thẩm quyền tối cao được tất cả mọi người tin tưởng: **Nhà cầm quyền Chứng thực (Certificate Authority – CA)**. CA ký xác nhận mối quan hệ giữa danh tính của Bob và khóa công khai của Bob.



S1-6 · Nghịch Lý Khóa Công Khai & Bản Chất Của PKI

[2 phút | 13h41–13h43] Nhấn mạnh bản chất của PKI: Không thể giải quyết bài toán tin cậy chỉ bằng thuật toán toán học. Bắt buộc phải có một điểm tựa tin cậy (Root of Trust) có tính tổ chức và pháp lý.

Định Nghĩa Chuẩn Về Chứng Chỉ Số (Digital Certificate)

Chứng chỉ số X.509 là một cấu trúc dữ liệu điện tử liên kết một khóa công khai với một thực thể sở hữu (chủ thể):

$$\text{Cert} = \{\text{TBSCertificate}, \text{SignatureAlgorithm}, \sigma_{\text{CA}}\}$$

Quy trình xác minh tính xác thực:

- Chữ ký số $\sigma_{\text{CA}} = \text{Sign}(K_{\text{priv_CA}}, \text{Hash}(\text{TBSCertificate}))$.
- Người nhận dùng khóa công khai $K_{\text{pub_CA}}$ có sẵn trong máy để kiểm tra σ_{CA}.
- Nếu chữ ký hợp lệ, người nhận tin tưởng tuyệt đối: **Khóa công khai này thuộc về đúng chủ thể được ghi trên chứng chỉ**.

Nguyên Lý Vàng Về Lòng Tin. Khóa bí mật của CA chính là điểm tựa tối cao (Root of Trust) của toàn bộ hệ thống. Mọi sự thỏa hiệp hoặc rò rỉ khóa CA đều dẫn đến sự sụp đổ dây chuyền của mọi chứng chỉ cấp dưới.


Định Nghĩa Chuẩn Về Chứng Chỉ Số (Digital Certificate)

Chứng chỉ số X.509 là một cấu trúc dữ liệu điện tử liên kết một khóa công khai với một thực thể sở hữu (chủ thẻ):

$$Cert = \{TBSCertificate, SignatureAlgorithm, \sigma_{CA}\}$$

Quy trình xác minh tính xác thực:

- Chữ ký số $\sigma_{CA} = Sign(K_{priv_CA}, Hash(TBSCertificate))$.
- Người nhận dùng khóa công khai K_{pub_CA} có sẵn trong máy để kiểm tra σ_{CA}.
- Nếu chữ ký hợp lệ, người nhận tin tưởng tuyệt đối: **Khóa công khai này thuộc về đúng chủ thể được ghi trên chứng chỉ.**

Nguyễn Lý Vàng Võ Lòng Tín. Khóa bí mật của CA chính là điểm tựa tối cao (Root of Trust) của toàn bộ hệ thống. Mọi sự thỏa hiệp hoặc rò rỉ khóa CA đều dẫn đến sự sụp đổ dây chuyền của mọi chứng chỉ cấp dưới.

S1-7 · Định Nghĩa Chuẩn Về Chứng Chỉ Số (Digital Certificate)

[2 phút | 13h43–13h45] Khẳng định vai trò của chữ ký CA: Đóng băng mối liên kết giữa Public Key và Định danh. Nếu kẻ tấn công thay đổi public key, chữ ký σ_{CA} sẽ lập tức bị sai.

3. Kiến trúc Phân tầng & Vòng đời Chứng chỉ

Lịch Sử & Nguồn Gốc Khái Niệm Chứng Chỉ Số

SELF-STUDY

Beyond · History & Context.

- **1976 – Diffie & Hellman:** Trao đổi khóa bất đối xứng (kế thừa Merkle Puzzles).
- **1977 – Rivest, Shamir, Adleman:** Hệ mật **RSA** và thuật toán chữ ký số đầu tiên.
- **1978 – Loren Kohnfelder (MIT):** Đề xuất thuật ngữ **Digital Certificate**, gắn kết khóa công khai với định danh pháp lý qua chữ ký số của bên thứ ba tin cậy.

Beyond · Why It Matters. Toán học mật mã chỉ xử lý dữ liệu và khóa vô danh K_{pub}. Không có chứng chỉ số, người nhận không thể phân biệt khóa của đối tác hợp pháp với khóa giả mạo của kẻ tấn công MitM.



S1-8 · Lịch Sử & Nguồn Gốc Khái Niệm Chứng Chỉ Số

SELF-STUDY

[Tự học | Lịch sử PKI] Loren Kohnfelder tại MIT năm 1978 chính là người đầu tiên đặt nền móng cho khái niệm chứng chỉ số X.509 ngày nay.

Suy Ngẫm & Thảo Luận Phản Biện Tại Lớp

Bản Chất Của Lòng Tin Trong Không Gian Số.

1. **Toán học vs Thực tế:** Vì sao mật mã vững chắc vẫn cần tổ chức CA giám sát?
2. **Web of Trust vs X.509:** Vì sao mô hình PGP phi tập trung thất bại trên quy mô toàn cầu, trong khi PKI phân tầng X.509 lại thống trị Internet?

Chìa Khóa Phản Biện. Toán học mật mã chỉ xử lý khóa. Lòng tin số đòi hỏi **tính pháp lý, quy trình thẩm định danh tính và cơ chế thu hồi**. PKI là cấu trúc thể chế hóa lòng tin trên không gian số.



S1-9 · Suy Ngẫm & Thảo Luận Phản Biện Tại Lớp

[3 phút | 13h45–13h48] PKI phân tầng thành công vì nó gắn liền với trách nhiệm pháp lý và quy chế vận hành rõ ràng.

Các Thành Phần Cơ Bản Của Hệ Thống PKI (RFC 5280)

Hạ tầng PKI không chỉ có mỗi CA mà bao gồm 5 thực thể chức năng:

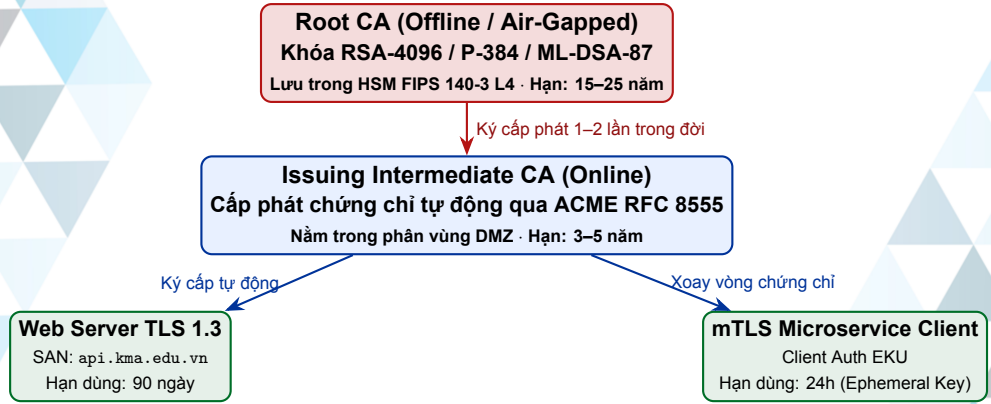
1. **Certification Authority (CA):** Tổ chức ký phát hành, gia hạn và thu hồi chứng chỉ số.
2. **Registration Authority (RA):** Cơ quan tiếp nhận hồ sơ, thẩm tra danh tính pháp lý trước khi chuyển lệnh ký sang CA.
3. **Repository (Kho lưu trữ công khai):** Máy chủ công bố chứng chỉ CA, chính sách CP/CPS và danh sách thu hồi CRL.
4. **Subscribers (Thuê bao):** Thực thể được cấp chứng chỉ (máy chủ web, lập trình viên, người dùng cá nhân).
5. **Relying Parties (Bên tin cậy):** Trình duyệt web, hệ điều hành tiến hành kiểm tra tính hợp lệ của chứng chỉ trước khi chấp nhận.



S1-10 · Các Thành Phần Cơ Bản Của Hệ Thống PKI (RFC 5280)

[2 phút | 13h45–13h47] Phân biệt rõ CA và RA: CA tập trung vào nghiệp vụ mật mã ký số an toàn. RA tập trung vào quy trình xác minh danh tính ngoài đời thực.

Kiến Trúc Chuỗi Tin Cậy Phân Tầng (3-Tier CA Hierarchy)





S1-11 · Kiến Trúc Chuỗi Tin Cậy Phân Tầng (3-Tier CA Hierarchy)

[3 phút | 13h47–13h50] Root CA ngắt mạng hoàn toàn (Air-gapped). Khi cấp chứng chỉ hàng ngày, chỉ có Intermediate CA trực tuyến làm việc. Nếu Intermediate CA bị lộ, Root CA chỉ cần ký 1 bản thu hồi CRL là xong.

Nghi Thức Lễ Sinh Khóa (Key Ceremony) & Chuẩn HSM

Khóa bí mật của Root CA được tạo ra trong một nghi thức pháp lý và kỹ thuật đặc biệt:

- **Phòng Kín Faraday (Air-gapped Clean Room):** Cách ly tuyệt đối sóng vô tuyến, giám sát camera an ninh đa góc quay liên tục.
- **Kiểm Soát Kép (Dual Control / M-of-N):** Phân rã quyền mở khóa HSM cho *N* người nắm giữ thẻ thông minh (Key Custodians) theo thuật toán Shamir; cần ít nhất *M* người có mặt đồng thời.
- **Thiết Bị Phần Cứng HSM (Hardware Security Module):**
  - Đạt tiêu chuẩn an ninh **NIST FIPS 140-2 / FIPS 140-3 Level 3 hoặc Level 4**.
  - Khóa bí mật sinh bằng bộ tạo số ngẫu nhiên vật lý (Hardware TRNG).
  - Cơ chế tự hủy khóa ngay lập tức (Zeroization) nếu phát hiện hành vi cạy nắp, thay đổi nhiệt độ hoặc điện áp.



S1-12 · Nghi Thức Lễ Sinh Khóa (Key Ceremony) & Chuẩn HSM

[3 phút | 13h50–13h53] Giới thiệu về quy chuẩn Key Ceremony và cơ chế Zeroization của HSM FIPS 140-3 Level 4.

Lời Khuyên Thực Chiến: Thiết Kế Chuỗi CA Bất Khả Xâm Phạm

Beyond · Pro-Tip & Practical Command.

- **Triệt tiêu rủi ro CA con:** Thiết lập `pathLenConstraint:0` trên Issuing Sub-CA, ngăn chặn kẻ tấn công lợi dụng để tự ký sinh thêm các CA cấp dưới.
- **Air-gapped tuyệt đối:** Root CA chỉ hoạt động offline cách ly vật lý. Mỗi năm chỉ khởi động 1–2 lần ký gia hạn CRL hoặc cấp Sub-CA mới.
- **Ký số Git Commit:** Kích hoạt ký SSH commit (`git config gpg.format ssh`) bảo đảm 100% mã nguồn có nguồn gốc danh tính rõ ràng.

Beyond · Critical Pitfall to Avoid. **Rò rỉ khóa bí mật lên Git:** Quên thêm `*.key` vào `.gitignore`. Khi đã commit, khóa vẫn nằm trong lịch sử Git. Kẻ tấn công quét bot có thể chiếm quyền CA trong tích tắc! Luôn cấu hình hook TruffleHog / Gitleaks.



S1-13 · Lời Khuyên Thực Chiến: Thiết Kế Chuỗi CA Bất Khả Xâm Phạm

[3 phút | 13h53–13h56] Cảnh báo học viên về lỗi sơ đẳng nhưng nguy hiểm nhất: commit file private key lên kho GitHub của nhóm.

4. Cấu trúc Dữ liệu X.509 v3 & Quy chuẩn CA/B Forum

Cấu Trúc Khung Nhị Phân ASN.1 DER (RFC 5280)

Chứng chỉ số được mã hóa nhị phân theo chuẩn **DER** với cấu trúc bộ ba TLV:

Cấu trúc TBSCertificate (RFC 5280):

- `version`: v3 (`0x02`)
- `serialNumber`: Định danh ngẫu nhiên (< 20B).
- `signature`: Thuật toán ký của CA.
- `issuer / subject`: Tên định danh DN.
- `validity`: Thời hạn (`notBefore` $\rightarrow$ `notAfter`).
- `subjectPublicKeyInfo`: Khóa công khai chủ thể.
- `extensions`: Danh sách mở rộng v3.

Quy Tắc Nhị Phân Cốt Lõi. Mã hóa DER bảo đảm **Canonical Form**: Một cấu trúc ASN.1 chỉ có duy nhất một biểu diễn nhị phân, loại bỏ nguy cơ tấn công biến dạng chữ ký số (Signature Malleability).



S1-14 · Cấu Trúc Khung Nhị Phân ASN.1 DER (RFC 5280)

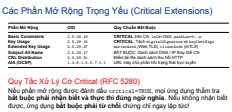
[3 phút | 13h53–13h56] Mổ xẻ cấu trúc TBSCertificate. Chữ ký số nằm ở cuối chứng chỉ là chữ ký trên toàn bộ khối nhị phân DER của TBSCertificate.

Các Phần Mở Rộng Trọng Yếu (Critical Extensions)

Phần Mở Rộng	OID	Quy Chuẩn Bắt Buộc
Basic Constraints	`2.5.29.19`	**CRITICAL** trên CA: `isCA=TRUE`, `pathLen=0..n`
Key Usage	`2.5.29.15`	**CRITICAL**: Tách `digitalSignature` vs `keyCertSign`
Extended Key Usage	`2.5.29.37`	`serverAuth` (Web TLS), `clientAuth` (mTLS)
Subject Alt Name	`2.5.29.17`	BẮT BUỘC: Danh sách DNS / IP thay thế CN
CRL Distribution	`2.5.29.31`	Điểm tải file danh sách thu hồi HTTP
AIA (OCSP)	`1.3.6.1.5.5.7.1.1`	URL máy chủ phản hồi trạng thái trực tuyến

Quy Tắc Xử Lý Cờ Critical (RFC 5280)

Nếu phần mở rộng được đánh dấu `critical=TRUE`, mọi ứng dụng thẩm tra **bắt buộc phải nhận biết và thực thi đúng ngữ nghĩa**. Nếu không nhận biết được, ứng dụng **bắt buộc phải từ chối** chứng chỉ ngay lập tức!


Các Phần Mở Rộng Trọng Yếu (Critical Extensions)

Phần Mở Rộng	OID	Quy Chuẩn Bắt Buộc
Basic Constraints	2.5.29.19	**CRITICAL** trên CA; luôn có `pathLenConstraint`
Key Usage	2.5.29.15	**CRITICAL** khi có; chỉ bật `keyCertSign` và `cRLSign` trên CA
Extended Key Usage	2.5.29.37	**CRITICAL** (RFC 5280); `clientAuth` (SVR-3)
Subject Alt Name	2.5.29.17	BẮT BUỘC: Danh sách DNS/ IP thay thế CN
CRL Distribution	2.5.29.31	Điểm tải tệp danh sách thu hồi HTTP
AIA (OCSP)	1.3.6.1.5.5.7.1.1	URL máy chủ phản hồi trạng thái trực tuyến

Quy Tắc Xử Lý Cờ Critical (RFC 5280)

Nếu phần mở rộng được đánh dấu `critical=TRUE`, mọi ứng dụng thẩm tra **bắt buộc phải nhận biết và thực thi đúng ngữ nghĩa**. Nếu không nhận biết được, ứng dụng **bắt buộc phải từ chối** chứng chỉ ngay lập tức!

S1-15 · Các Phần Mở Rộng Trọng Yếu (Critical Extensions)

[3 phút | 13h56–13h59] Giải thích tầm quan trọng của cờ Critical: Ngăn chặn các phần mềm bỏ qua các ràng buộc an ninh quan trọng.

Quy Định Khai Tử Common Name (CN) & Bắt Buộc SAN

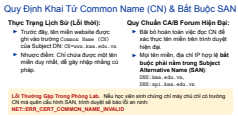
Thực Trạng Lịch Sử (Lỗi thời):

- Trước đây, tên miền website được ghi vào trường `Common Name (CN)` của Subject DN: `CN=www.kma.edu.vn`
- Nhược điểm: Chỉ chứa được một tên miền duy nhất, dễ gây nhập nhằng cú pháp.

Quy Chuẩn CA/B Forum Hiện Đại:

- Bãi bỏ hoàn toàn việc đọc CN để xác thực tên miền trên trình duyệt hiện đại.
- Mọi tên miền, địa chỉ IP hợp lệ **bắt buộc phải nằm trong Subject Alternative Name (SAN)**:
  `DNS:kma.edu.vn`,
  `DNS:api.kma.edu.vn`

Lỗi Thường Gặp Trong Phòng Lab. Nếu học viên sinh chứng chỉ máy chủ chỉ có trường CN mà quên cấu hình SAN, trình duyệt sẽ báo lỗi an ninh:
NET::ERR_CERT_COMMON_NAME_INVALID



S1-16 · Quy Định Khai Tử Common Name (CN) & Bắt Buộc SAN

[2 phút | 13h59–14h01] Nhắc nhở học viên khi làm bài Lab 1 và Lab 4: Bắt buộc phải thêm phần mở rộng SAN trong file openssl.cnf, không được chỉ ghi CN.

5. Xác thực Đường dẫn & Cơ chế Thu hồi Chứng chỉ

Thuật Toán Xác Thực Chuỗi Tin Cậy (RFC 5280 §6)

Khi nhận được chứng chỉ từ máy chủ Web, Client duyệt ngược chuỗi tin cậy:

$$C_{\text{Leaf}} \rightarrow C_{\text{Intermediate}} \rightarrow C_{\text{Root (Trust Store)}}$$

6 Bước Kiểm Tra Bắt Buộc:

1. **Chữ ký số:** Dùng Public Key của CA cha kiểm tra chữ ký của chứng chỉ con.
2. **Thời gian hiệu lực:** $T_{\text{hiện_tại}} \in [\text{notBefore}, \text{notAfter}]$.
3. **Khớp nối tên định danh (Name Chaining):** $C_{\text{child}}.\text{Issuer} == C_{\text{parent}}.\text{Subject}$.
4. **Quyền hạn CA:** Mọi mắt xích cha phải có `basicConstraints.isCA=TRUE`.
5. **Độ sâu chuỗi (Path Length):** Số lượng cấp CA không vượt quá `pathLenConstraint`.
6. **Trạng thái thu hồi:** Chứng chỉ không nằm trong CRL và không bị OCSP báo `REVOKED`.



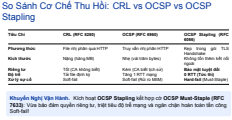
S1-17 · Thuật Toán Xác Thực Chuỗi Tin Cậy (RFC 5280 §6)

[3 phút | 14h01–14h04] Trình bày 6 bước của thuật toán Path Validation theo RFC 5280. Đây là nội dung cốt lõi sẽ được kiểm tra trong đề thi.

So Sánh Cơ Chế Thu Hồi: CRL vs OCSP vs OCSP Stapling

Tiêu Chí	CRL (RFC 5280)	OCSP (RFC 6960)	OCSP Stapling (RFC 6066)
Phương thức	File nhị phân qua HTTP	Truy vấn nhị phân HTTP	Kẹp trong gói TLS Handshake
Kích thước	Nặng (hàng MB)	Nhẹ (vài trăm bytes)	Không tốn thêm kết nối ngoài
Riêng tư	Tốt (CA không biết)	Kém (CA biết lịch sử)	**Bảo mật tuyệt đối**
Độ trễ	Tải file định kỳ	Tăng 1 RTT mạng	**0 RTT (Tức thì)**
Xử lý sự cố	Soft-fail	Soft-fail (Rủi ro MitM)	**Hard-fail** (Must-Staple)

Khuyến Nghị Vận Hành. Kích hoạt **OCSP Stapling** kết hợp cờ **OCSP Must-Staple (RFC 7633)**: Vừa bảo đảm quyền riêng tư, triệt tiêu độ trễ mạng và ngăn chặn hoàn toàn tấn công Soft-fail!



So Sánh Cơ Chế Thu Hồi: CRL vs OCSP vs OCSP Stapling

Tiêu Chí	CRL (RFC 5280)	OCSP (RFC 6960)	OCSP Stapling (RFC 6066)
Phương thức	File tải phân qua HTTP	Truy vấn từng phần HTTP	Kẹp trong gói TLS Handshake
Kích thước	Nặng (hàng MB)	Nhẹ (vài trăm bytes)	Không tốn thêm bất kỳ băng thông
Riêng tư	Tốt (CA không biết)	Kém (CA biết bạn vào)	**Bảo mật tuyệt đối**
Độ trễ	Tải file định kỳ	Tăng 1 RTT mạng	**0 RTT (Tức thì)**
Độ tự sự cố	Sinh hại	Sinh hại (Phụ vì Mỹ)	**Need-but (Must-Staple)**

Khuyến Nghị Vận Hành. Kích hoạt **OCSP Stapling** kết hợp cờ **OCSP Must-Staple (RFC 7633)**: Vừa bảo đảm quyền riêng tư, triệt tiêu độ trễ mạng và ngăn chặn hoàn toàn tấn công Soft-fail

S1-18 · So Sánh Cơ Chế Thu Hồi: CRL vs OCSP vs OCSP Stapling

[3 phút | 14h04–14h07] So sánh 3 cơ chế thu hồi. Phân tích rõ tại sao OCSP Stapling lại là tiêu chuẩn vàng của ngành Web hiện nay.

6. Bối cảnh Tấn công & Di chuyển Hậu Lượng tử (PQC)

Các Thảm Họa PKI Điển Hình Trong Lịch Sử

Vụ Án DigiNotar (Hà Lan - 2011):

- Hacker thâm nhập mạng nội bộ CA do thiếu phân tách vùng mạng.
- Phát hành 500+ chứng chỉ giả mạo cho `*.google.com`, `*.torproject.org`.
- 300.000+ người dùng bị nghe lén toàn bộ tài khoản email/web.
- Hậu quả: DigiNotar bị trục xuất khỏi mọi Trust Store và phá sản hoàn toàn.

Vũ Khí Mạng Flame (2012):

- Khai thác va chạm tiền ảnh (chosen-prefix collision) trên hàm băm MD5.
- Giả mạo chứng chỉ số dịch vụ Microsoft Terminal Server.
- Đột lốt bản cập nhật Windows Update hợp lệ để phát tán mã độc gián điệp vào hạ tầng năng lượng.



S1-19 · Các Thảm Họa PKI Điển Hình Trong Lịch Sử

[3 phút | 14h07–14h10] Phân tích 2 bài học lịch sử lớn nhất của ngành PKI: DigiNotar (sự cố quản trị) và Flame (sự cố toán học va chạm MD5).

Bài Học Xương Máu: Certificate Transparency & ZLint

Beyond · Why It Matters. **Điểm yếu cố hữu của PKI truyền thống:** Khi một CA bị thâm nhập và âm thầm phát hành chứng chỉ giả mạo, chủ sở hữu tên miền hoàn toàn không có cách nào phát hiện sự tồn tại của chứng chỉ đó!

Cơ Chế Giám Sát Chủ Động Toàn Cầu.

- **Certificate Transparency (RFC 6962):** Mọi chứng chỉ công khai bắt buộc phải được ghi vào các sổ cái Merkle Tree công khai (CT Logs) trước khi được trình duyệt chấp nhận.
- **Bộ công cụ kiểm định ZLint:** Tự động đối chiếu hơn 300 quy chuẩn IETF RFC 5280 và CA/B Forum Baseline Requirements.



S1-20 · Bài Học Xương Máu: Certificate Transparency & ZLint

[2 phút | 14h10–14h12] Giới thiệu sự ra đời của Certificate Transparency và công cụ ZLint như lá chắn giám sát toàn cầu.

Khai Thác Active Directory Certificate Services (AD CS)

Nghiên cứu của SpecterOps (2021) chỉ ra các lỗ hổng leo thang đặc quyền nghiêm trọng:

- **Lỗ hổng ESC1 (Misconfigured Template):** Mẫu chứng chỉ cấp cờ `ENROLLEE_SUPPLIES_SUBJECT` kết hợp EKU `Client Authentication`, cho phép người dùng thường mạo danh `Domain Admin`.
- **Lỗ hổng ESC8 (NTLM Relay to Web Enrollment):** Kẻ tấn công relay gói tin NTLM sang cổng web HTTP của CA để yêu cầu cấp chứng chỉ máy và chiếm toàn bộ mạng Active Directory.

Phòng Ngự Kỹ Thuật (Đề tài Đồ án Nhóm 2).

- Bỏ cờ `ENROLLEE_SUPPLIES_SUBJECT` trên các mẫu chứng chỉ nhạy cảm.
- Giám sát Windows Event Log ID `4886` và `4887` bằng hệ thống Sigma rules.



S1-21 · Khai Thác Active Directory Certificate Services (AD CS)

[2 phút | 14h10–14h12] Giới thiệu sơ lược về AD CS ESC1/ESC8. Đây là chủ đề đồ án của Nhóm 2 (Hiển, Sơn, Phú).

Mối Đe Dọa Lượng Tử & Bộ Tiêu Chuẩn NIST FIPS 203/204

Nguy Cơ Sụp Đổ Mật Mã:

- Thuật toán Shor trên máy tính lượng tử giải quyết bài toán thừa số nguyên tố và DLP trong thời gian đa thức $\mathcal{O}((\log N)^3)$.
- Toàn bộ RSA và ECC sẽ sụp đổ hoàn toàn.
- Tấn công **Harvest Now, Decrypt Later (HNDL)** đang diễn ra: Dữ liệu mã hóa hôm nay đang bị thu thập để giải mã trong tương lai!

Chuẩn NIST Mới Nhất (08/2024).

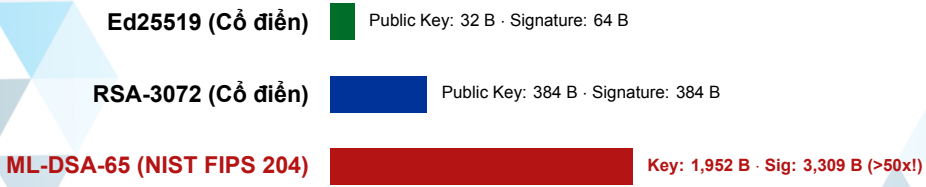
- **NIST FIPS 203 (ML-KEM):** Đóng gói khóa mạng lưới Module-LWE (Kyber).
- **NIST FIPS 204 (ML-DSA):** Chữ ký số mạng lưới Module-LWE (Dilithium).
- **NIST FIPS 205 (SLH-DSA):** Chữ ký số hàm băm phi trạng thái (SPHINCS+).



S1-22 · Mối Đe Dọa Lượng Tử & Bộ Tiêu Chuẩn NIST FIPS 203/204

[3 phút | 14h12–14h15] Giới thiệu về PQC và chuẩn mới nhất ban hành tháng 8/2024 của NIST. Nhấn mạnh khái niệm Harvest Now, Decrypt Later.

Infographic: So Sánh Kích Thước Khóa & Chữ Ký Cổ Điển vs PQC



Thách Thức Kỹ Thuật Đồ Án Nhóm 3 (PQC Migration):
Chữ ký ML-DSA lớn hơn kích thước 1 khung tin TCP MTU (1500 bytes), dẫn tới phân mảnh gói tin IP và tăng độ trễ bắt tay mạng trên đường truyền vô tuyến.



S1-23 · Infographic: So Sánh Kích Thước Khóa & Chữ Ký Cổ Điển vs PQC

[3 phút | 14h15–14h18] Biểu đồ so sánh kích thước: Trực quan hóa lý do vì sao chuyển dịch PQC lại khó về mặt kỹ thuật mạng.

Thách Thức Nghiên Cứu Mật Mã Hậu Lượng Tử (PQC)

SELF-STUDY

Beyond · Open Problem & Future.

- **1. Phân mảnh gói tin TCP do chữ ký PQC quá lớn:** Chữ ký ML-DSA-65 dài 3,309 bytes, vượt quá MTU chuẩn (1500 bytes), làm tăng độ trễ mạng trong TLS Handshake.
- **2. Chống tấn công Harvest Now, Decrypt Later (HNDL):** Cần triển khai kiến trúc chứng chỉ kép lai (Hybrid X.509 Certificate – RFC 9881), kết hợp song song chữ ký cổ điển (ECDSA) và PQC (ML-DSA).
- **3. Zero-Knowledge Proofs (ZKP) cho Định Danh Riêng Tư:** PKI thế hệ mới cho phép chứng minh sở hữu chứng chỉ hợp lệ mà không để lộ danh tính cá nhân.



S1-24 · Thách Thức Nghiên Cứu Mật Mã Hậu Lượng Tử (PQC)

SELF-STUDY

[Tự học | Đề tài nghiên cứu] Giới thiệu 3 bài toán mở thời sự làm định hướng đề tài nghiên cứu chuyên sâu hoặc luận văn thạc sĩ.

7. Môi trường Thực hành & Phân công Đồ án

Môi Trường Thực Hành Chuẩn Hóa Docker Compose

Toàn bộ các bài thực hành và đồ án môn học được đóng gói sẵn trong Docker:

- **OpenSSL 3.5.0-dev + liboqs:** Biên dịch sẵn hỗ trợ toàn diện các thuật toán PQC (ML-KEM, ML-DSA).
- **SoftHSMv2:** Môi trường giả lập HSM phần cứng chuẩn PKCS#11.
- **Step-CA:** Máy chủ ACME RFC 8555 độc lập cho mạng private.

Khởi Động Nhanh Môi Trường Thực Hành (Lab 1)

```
$ git clone https://github.com/KMA-PKI-261/PKI-261-Courseware.git
$ cd PKI-261-Courseware/Lab-Framework
$ docker compose up -d && docker compose exec pki-lab bash
```



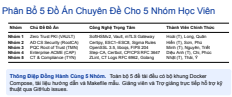
S1-25 · Môi Trường Thực Hành Chuẩn Hóa Docker Compose

[2 phút | 14h18–14h20] Hướng dẫn học viên clone kho bài tập và khởi động Docker container.

Phân Bổ 5 Đồ Án Chuyên Đề Cho 5 Nhóm Học Viên

Nhóm	Chủ Đề Đồ Án	Công Nghệ Trọng Tâm	Thành Viên Chính Thức
Nhóm 1	Zero Trust PKI (VAULT)	SoftHSMv2, Vault, mTLS Gateway	Hoài (T), Long, Quân
Nhóm 2	AD CS Security (RootCA)	Certipy, ESC1–ESC8, Sigma Rules	Hiển (T), Sơn, Phú
Nhóm 3	PQC Root of Trust (TMN)	OpenSSL 3.5, liboqs, FIPS 204	Minh (T), Nguyên, Triết
Nhóm 4	Enterprise ACME (CAP)	Step-CA, Certbot, CP/CPS RFC 3647	Diệu Anh (T), Chi, Phúc
Nhóm 5	CT & Compliance (TYN)	ZLint, CT Logs RFC 6962, Golang	Nhật (T), Thái, Ý

Thông Điệp Đồng Hành Cùng 5 Nhóm. Toàn bộ 5 đề tài đều có bộ khung Docker Compose, tài liệu hướng dẫn và Makefile mẫu. Giảng viên và Trợ giảng trực tiếp hỗ trợ kỹ thuật qua GitHub issues.



Phân Bổ 5 Đồ Án Chuyên Đề Cho 5 Nhóm Học Viên

Nhóm	Chủ Đề Đồ Án	Công Nghệ Trọng Tâm	Thành Viên Chính Thức
Nhóm 1	Zero Trust PKI (VAULT)	SoftHSM2, Vault, mTLS Gateway	Hoài (T), Long, Quân
Nhóm 2	Hệ Thống Chữ Ký Số (DSS)	Java, Spring Boot, Docker, MySQL	Hiếu (T), Nam, Tuấn
Nhóm 3	PQC Hybrid TLS (TWIN)	OpenSSL 3.5, liboqs, TWIN API	Minh (T), Nguyễn, Tiến
Nhóm 4	Enterprise ACME (CAP)	Step-CA, CertSet, CPCPS RFC 3647	Dũng Anh (T), Chi, Phúc
Nhóm 5	ICT & Compliance (TTN)	JCoX, CT Logs RFC 6962, Golang	Khải (T), Thắ, Y

Thông Điệp Đồng Hành Cùng 5 Nhóm. Toàn bộ 5 đề tài đều có bộ khung Docker Compose, tài liệu hướng dẫn và Makefile mẫu. Giảng viên và Trợ giảng trực tiếp hỗ trợ kỹ thuật qua GitHub Issues.

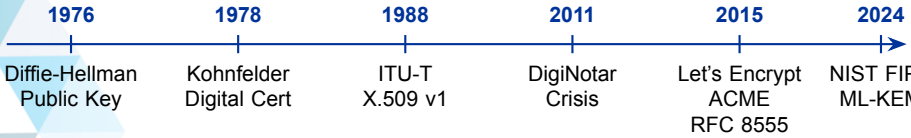
S1-26 · Phân Bổ 5 Đồ Án Chuyên Đề Cho 5 Nhóm Học Viên

[3 phút | 14h20–14h23] Công bố danh sách chính thức 5 nhóm theo MASTER-DIEU-PHOI-HOC-PHAN.md.

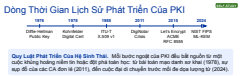
8. Gói Tự Học & Ôn Tập Nâng Cao (Self-Study Pack)

SELF-STUDY

Dòng Thời Gian Lịch Sử Phát Triển Của PKI



Quy Luật Phát Triển Của Hệ Sinh Thái. Mỗi bước ngoặt của PKI đều bắt nguồn từ một cuộc khủng hoảng niềm tin hoặc đột phá toán học: từ bài toán mạo danh sơ khai (1978), sự sụp đổ của các CA đơn lẻ (2011), đến cuộc đại di chuyển trước mối đe dọa lượng tử (2024).



S1-1 · Dòng Thời Gian Lịch Sử Phát Triển Của PKI

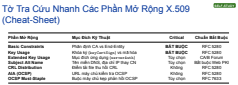
SELF-STUDY

[Tự học | Lịch sử] Trực quan hóa tiến trình nửa thế kỷ phát triển của PKI trên một trục thời gian duy nhất.

SELF-STUDY

Tờ Tra Cứu Nhanh Các Phần Mở Rộng X.509 (Cheat-Sheet)

Phần Mở Rộng	Mục Đích Kỹ Thuật	Critical	Chuẩn Bắt Buộc
Basic Constraints	Phân định CA vs End-Entity	**BẮT BUỘC**	RFC 5280
Key Usage	Khóa ký (`keyCertSign`) vs mã hóa	**BẮT BUỘC**	RFC 5280
Extended Key Usage	Mục đích ứng dụng (`serverAuth`)	Tùy chọn	CA/B Forum
Subject Alt Name	Tên miền DNS, địa chỉ IP thay CN	Tùy chọn	Bắt buộc Web PKI
CRL Distribution	Điểm tải file thu hồi CRL	Không	RFC 5280
AIA (OCSP)	URL máy chủ kiểm tra OCSP	Không	RFC 5280
OCSP Must-Staple	Buộc máy chủ kẹp phản hồi OCSP	Tùy chọn	RFC 7633


Tờ Tra Cứu Nhanh Các Phần Mở Rộng X.509 (Cheat-Sheet)

SELF-STUDY

Phần Mở Rộng	Mục Đích Kỹ Thuật	Critical	Chuẩn Bắt Buộc
Basic Constraints	Phân định CA và End-Entity	**BẮT BUỘC**	RFC 5280
Key Usage	Khóa Ký (keyCertSign) và Mã Hóa	**BẮT BUỘC**	RFC 5280
Extended Key Usage	Mục đích (Máy chủ, Người dùng)	Tùy chọn	CA/B Forum
Subject Alt Name	Tên miền (DNS), địa chỉ IP (Bắt buộc)	Tùy chọn	Bắt buộc Web PKI
CRL Distribution	URL nơi tải về danh sách thu hồi	Không	RFC 5280
AIA (OCSP)	URL nơi kiểm tra trực tuyến OCSP	Không	RFC 5280
OCSP Must-Staple	Bước máy chủ tiếp phải hỏi OCSP	Tùy chọn	RFC 7633

S1-2 · Tờ Tra Cứu Nhanh Các Phần Mở Rộng X.509 (Cheat-Sheet)

SELF-STUDY

[Tự học | Tra cứu] Bảng cheat-sheet tóm tắt các thuộc tính X.509 trọng yếu dùng để tra cứu nhanh khi làm bài Lab và thi cử.

Bộ Câu Hỏi Thẩm Định Năng Lực Buổi Học S01

Bộ Câu Hỏi Thẩm Định Năng Lực Buổi Học S01.

1. **Câu hỏi 1:** Tại sao cờ `basicConstraints` bắt buộc phải được đánh dấu là `critical=TRUE` trên chứng chỉ CA trung gian? Điều gì xảy ra nếu cờ này là `non-critical`?
   Giải đáp: Nếu không đánh dấu critical, các ứng dụng xác thực cũ có thể bỏ qua việc kiểm tra thuộc tính này và chấp nhận chứng chỉ máy chủ web làm CA, dẫn đến nguy cơ bất kỳ ai cũng có thể tự ký cấp chứng chỉ giả mạo!
2. **Câu hỏi 2:** Trong lễ sinh khóa (Key Ceremony), vì sao người ta dùng cơ chế *M*-of-*N* Shamir Secret Sharing mà không giao toàn quyền cho một quản trị viên cao nhất?
   Giải đáp: Loại bỏ hoàn toàn điểm yếu đơn lẻ (Single Point of Failure), ngăn chặn rủi ro nội bộ (Insider Threat), tống tiền hoặc sơ suất cá nhân. Bắt buộc phải có sự đồng thuận của ít nhất *M* người giám sát độc lập.


Bộ Câu Hỏi Thẩm Định Năng Lực Buổi Học S01

Bộ Câu Hỏi Thẩm Định Năng Lực Buổi Học S01.

1. **Câu hỏi 1**: Tại sao cờ basicConstraints bắt buộc phải được đánh dấu là critical=TRUE trên chứng chỉ CA trung gian? Điều gì xảy ra nếu cờ này là non-critical=FALSE?
   Gợi ý: Nếu không đánh dấu critical, các ứng dụng xác thực cũ có thể bỏ qua việc kiểm tra thuộc tính này và chấp nhận chứng chỉ này như một web làm CA, dẫn đến nguy cơ bất kỳ ai cũng có thể tự ký cấp chứng chỉ giả mạo!
2. **Câu hỏi 2**: Trong lễ sinh khóa (Key Ceremony), vì sao người ta dùng cơ chế M-of-N (ví dụ 3-of-5) để chia sẻ khóa bí mật cho Thành viên cấp cao nhất? Giải thích: Loại bỏ hoàn toàn điểm yếu từ một cá nhân — dù một người (hoặc một số ít) có nội bộ (Insider Threat), tổng tiền hoặc xe xuất cá nhân. Bắt buộc phải có sự đồng thuận của ít nhất M người giám sát độc lập.

S1-3 · Bộ Câu Hỏi Thẩm Định Năng Lực Buổi Học S01

[3 phút | 14h21–14h24] Cho học viên 1 phút suy nghĩ và trả lời 2 câu hỏi ôn tập. Đáp án chi tiết hiển thị trong bản giáo án của GV và bản ghi chú.

Tóm Tắt Buổi Học & Chuẩn Bị Tuần Tiếp Theo (S02)

Nội Dung Đã Nắm Vững (S01):

- Bản chất bài toán Identity Binding của PKI.
- Mô hình phân tầng 3 cấp: Root CA $\rightarrow$ Intermediate CA $\rightarrow$ End-Entity.
- Nghi thức Key Ceremony & HSM FIPS 140-3.
- Các kịch bản tấn công và lộ trình PQC.

Nhiệm Vụ Tuần Tiếp Theo (S02):

- Đọc Chương 2 của **Tài liệu học tập**.
- Hoàn thành bài Lab 1: Khởi tạo Root CA và Sub-CA bằng OpenSSL 3.5.
- Họp nhóm đồ án lần 1, phân công vai trò kỹ thuật theo Makefile mẫu.

Xin cảm ơn các anh chị học viên! Chúc lớp có một học kỳ thành công xuất sắc!



S1-4 · Tóm Tắt Buổi Học & Chuẩn Bị Tuần Tiếp Theo (S02)

[2 phút | 14h23–14h25] Tổng kết buổi học, giải đáp thắc mắc và hẹn gặp lại học viên vào 13h30 chiều Thứ Bảy tuần sau.